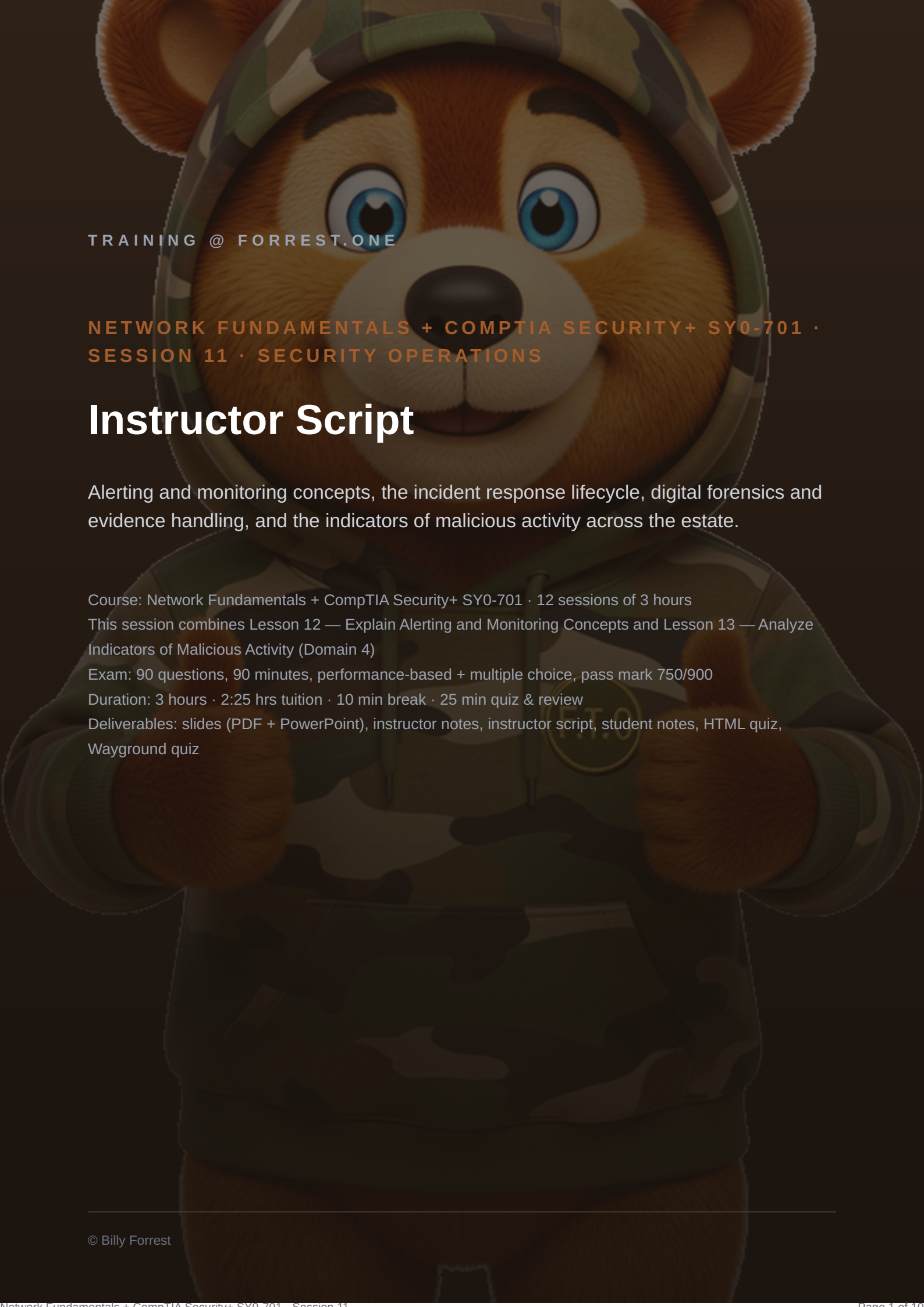




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 11 · SECURITY OPERATIONS

Instructor Script

Alerting and monitoring concepts, the incident response lifecycle, digital forensics and evidence handling, and the indicators of malicious activity across the estate.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lesson 12 — Explain Alerting and Monitoring Concepts and Lesson 13 — Analyze Indicators of Malicious Activity (Domain 4)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script — Security Operations: Monitoring, Incident Response & Forensics

A word-for-word delivery script for Session 11. Stage directions appear in square brackets. Each slide runs roughly 45 to 90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Welcome to Session 11: Security Operations, Monitoring, Incident Response and Forensics. Sessions 1 to 10 prevented, detected and hardened. Today we work in the moment something gets through. Six chapters: the devices that watch the network, the controls that guard endpoints and data, identity and automation, incident response, threat hunting and forensic evidence, and finally logs.

Slide 2 · Where we are

A quick orientation. This is Domain 4, the largest on the exam at twenty-eight percent, so it carries real weight. Everything here happens after prevention has already failed, and the exam rewards sequence: phases and steps in the right order. Watch the order throughout, because a scenario question is usually testing whether you know what comes next.

Slide 3 · Session objectives

By the end of these three hours you will be able to compare firewall types; place DNS filtering, data loss prevention, network access control and endpoint detection at the right layer; protect identity through provisioning and privileged access; automate safely; run incident response through its four phases; hunt, investigate and preserve evidence; and read indicators of malicious activity. Seven objectives, and the quiz tests every one.

Slide 4 · Firewall types

Firewalls stand between trusted internal networks and untrusted external ones, and the exam tests what each generation can see. A packet filtering firewall works at the network layer, checking source address, destination address, protocol and port against predefined rules. It is fast, but it tracks no connection state and it cannot see inside the payload. A stateful inspection firewall keeps a state table, so it judges each packet by the conversation it belongs to. And a next-generation firewall, an NGFW, adds application awareness, deep packet inspection and intrusion prevention. It sees the application, not merely the port. Each type adds context the one before it could not see.

Slide 5 · Firewall rules and segmentation

Rules are where firewalls are won or lost. Rule creation must be specific, so only authorised traffic passes. Change control adds documentation, review and approval, so no change quietly weakens the rule set. Regular review removes obsolete and redundant rules that nobody remembers adding; a forgotten allow rule is a permanent hole. Firewalls also enforce segmentation. They separate the corporate network from the guest network, and a demilitarized zone, or DMZ, from the internal zone, so each area carries its own policy and the attack surface shrinks.

Slide 6 · Web application firewalls

A web application firewall, a WAF, is a specialist. It operates at the application layer and reads HTTP and HTTPS requests rather than packets. Its targets are the classic web attacks, including injection written in Structured Query Language, and cross-site scripting. Internet-facing applications are the ones attackers reach most easily, which is why they attract so much attention. By filtering and monitoring requests, the WAF blocks the attempt before it reaches the application. The request is where the attack arrives, so that is where you answer it.

Slide 7 · Intrusion detection and prevention

Now detection. An intrusion detection system, an IDS, is passive: it watches traffic, spots suspicious activity and alerts administrators, but it takes no direct action. An intrusion prevention system, an IPS, detects and then acts, dropping malicious packets, blocking traffic from suspicious addresses and resetting connections. Deployment matters as much as the definition. A network-based sensor sits at a gateway and sees traffic entering and leaving. A host-based agent sits on a server or workstation, which is how you catch activity that starts from inside.

Slide 8 · Two ways to detect

Two detection methods sit underneath both systems. Signature-based detection compares traffic against a database of known attack patterns. It is highly effective against known threats, and blind to a novel technique until the signature database is updated. Anomaly-based detection builds a baseline of normal behaviour and alerts on deviation from it. It can catch unknown threats, at the cost of more false positives, because legitimate change looks suspicious. Tuning balances them: update signatures, adjust thresholds, allowlist known good activity, and review the alerts regularly. That balance is the job, because an untuned sensor becomes wallpaper.

Slide 9 · Analyst's lens: the host's own log

Here is a monitoring source people overlook. On a Kali Linux box, the xrdp system log records every Remote Desktop Protocol, or RDP, connection to that machine. It shows successful and failed authentication attempts, session start and session stop, and the source address and port behind each attempt. An analyst reads it for a run of failures followed by a success from one address, which suggests brute force that eventually worked.

A login at an unusual time, or from a network that never normally connects, deserves the same attention. Monitor the host, not only the network.

Slide 10 · Discussion

[Run the discussion per the instructor notes.] The IDS has been alerting all week, and the team has stopped reading it. What has failed, and what do you fix first? [Take answers.] The detection did not fail; the alerting did. Baselines, thresholds and tuning restore the signal. Until then, real incidents sit unread in a queue nobody trusts.

Slide 11 · Domain Name System filtering

Domain Name System filtering blocks access to domains that are malicious or against policy. Every connection begins with a name resolution query, because people use names and machines use addresses. The filter intercepts that query and checks the requested domain against a blocklist or an allowlist. A blocked domain is denied, and the user sees a warning page or an error message. Because the connection is stopped before it is established, this works well against phishing sites and malware distribution sites, and it enforces policy. The cheapest place to stop a connection is before it starts.

Slide 12 · Data loss prevention

Data loss prevention, or DLP, watches the movement of sensitive data. It monitors, detects and controls information crossing the network and the endpoint. Network DLP watches data in motion across the network, while endpoint DLP watches data at rest and data in use on the device itself. Rules identify sensitive content by content, context and user action, and the response can alert an administrator, block the transfer, or encrypt the data. The classic case: an employee emails a client file to a personal address, and the system stops it.

Slide 13 · Network access control

Network access control, or NAC, decides who gets onto the network in the first place. Before a device connects, the system checks its antivirus status, its operating system updates and the user credentials. A device that meets the criteria is allowed on. A device that fails is denied, or placed in a restricted segment until it complies. That is the difference between a control that reacts and a control that simply refuses entry. Put the three together: filtering blocks the domains, DLP guards the data, and NAC guards the devices.

Slide 14 · Endpoint detection and response

Traditional antivirus scans files against a database of known malware signatures. That works against known threats, and struggles with zero-day attacks and advanced persistent threats, which have no signature yet. Endpoint detection and response, or EDR, watches behaviour instead. It monitors processes, file modifications and network connections on the endpoint. When a process opens sensitive files or makes an unusual connection, EDR flags it for investigation. It hands the analyst process trees and telemetry rather than a simple verdict.

Slide 15 · Alert investigation workflow

Extended detection and response, or XDR, takes the same idea beyond the endpoint, correlating endpoint, network and cloud data in one view. The workflow is what you follow. Alert triage prioritises by severity and potential impact. Threat analysis reviews the telemetry. Contextualisation establishes origin, affected systems and indicators of compromise. Response planning decides containment or eradication. Remediation restores the system, patches it, and captures the lessons. Automated responses include isolating an endpoint, quarantining a file, blocking an address and revoking credentials. It shortens the time from alert to action.

Slide 16 · Provisioning and the user lifecycle

Identity and access management, or IAM, controls who has access to what. Provisioning creates accounts with the right permissions and roles. As people change roles, their access is modified, so nobody keeps rights they no longer need. When someone leaves, the account is deactivated or removed, and promptly. That is the user lifecycle: onboarding, role changes, and offboarding. Offboarding is where organisations fail. An account left active after an employee has gone is an open door, and it is one of the most common audit findings.

Slide 17 · Single sign-on, directories and federation

Single sign-on, or SSO, lets one set of credentials open many systems. It reduces password fatigue and simplifies the user experience, but it is also a single point of failure, so pair it with multifactor authentication. Directory services are the central database of identities: Microsoft Active Directory, Lightweight Directory Access Protocol, or LDAP, and cloud directories. Federation links identity systems across organisations using trust, with an identity provider issuing a token the service provider accepts. Identity governance keeps it honest through access reviews, policy enforcement and audit reporting.

Slide 18 · Multifactor authentication

Multifactor authentication, or MFA, requires more than one form of proof. Something you know, such as a password or a pin. Something you have, such as a phone, a smart card or a hardware token. Something you are, such as a fingerprint, a face or an iris. Combining factors from different categories is what defeats a stolen password. Implementations include authenticator applications that generate time-based one-time passwords, hardware tokens, and biometrics. And remember: two passwords are still a single factor.

Slide 19 · Privileged access management

Privileged access management, or PAM, controls the accounts that can do real damage. Just-in-time access grants elevated permissions only when they are needed, and revokes them automatically afterwards, which shrinks the window an attacker can use. Session recording captures keystrokes, commands and applications during a privileged session, which is invaluable for audit and for forensics. Password vaulting stores privileged credentials in an encrypted vault and rotates them automatically. Nobody memorises the password, and every use is logged and attributable to a person.

Slide 20 · Automation use cases

Automation performs security tasks with little or no human intervention, and it reduces both delay and human error. Automated patching scans for updates, tests them in a controlled environment, and deploys them, which shortens the window of exposure to a known vulnerability. Automated account provisioning grants and revokes access promptly, which matters where staff change role often. Incident response playbooks execute predefined steps: isolating affected systems, notifying the right people, and collecting forensic data. The playbook is the difference between responding in seconds and responding tomorrow.

Slide 21 · Orchestration, scripting and guardrails

Orchestration coordinates those automated tasks into one workflow, in the correct sequence. A workflow might detect a threat, trigger a patch deployment, and update the threat intelligence database without a human touching it. Scripting adds customisation, efficiency and consistency, because a script performs the same steps every single time. But automation needs guardrails: test changes in a controlled environment, restrict who may modify the scripts, and log every automated action. Human oversight stays necessary for complex judgement, for exceptions, and for decisions with ethical weight. Automate the routine, and keep a person on the judgement.

Slide 22 · Break

Ten minutes. When we return: incident response, the four phases, in the order the exam expects. Preparation first, always.

Slide 23 · The four phases

Incident response limits damage and shortens recovery, and it runs through four phases. Preparation builds the capability: policy, tools, a written plan, trained people and rehearsals. Detection and analysis identify the incident, then work out its scope and severity, using monitoring tools and a security information and event management system, a SIEM. Containment, eradication and recovery isolate affected systems, remove the cause such as malware or a closed vulnerability, and restore from validated backups. Lessons learned documents the incident and improves the next response. The order is examined directly, and preparation comes first.

Slide 24 · Containment, eradication and recovery

Containment and eradication are different jobs. Containment strategy means short-term isolation first, then long-term control: the segment pulled, then the systems rebuilt. The trade-off is real: containment preserves evidence but can alert the adversary, who may accelerate or cover their tracks. Eradication removes the malware, revokes the credentials and closes the hole. Recovery restores from validated backups and verifies integrity, and monitoring is intensified afterwards to watch for re-infection. The exam line: containment stops the bleeding, eradication stops the cause.

Slide 25 · Classification, severity and roles

Every incident is classified and graded, because that drives urgency. Classification covers unauthorised access, malware, denial of service and data breach. Severity runs low, medium, high and critical, from minimal impact with no sensitive data involved, up to severe impact with widespread exposure and regulatory consequences. Roles matter as much as phases. Incident handlers detect, analyse, contain, eradicate and recover. Management provides oversight and resources. Legal keeps the response compliant and protects the evidence. Communications keeps stakeholders informed and protects reputation. Severity drives urgency, and a named role removes hesitation.

Slide 26 · Tabletop, functional and full-scale

Preparation is tested with exercises, and there are three kinds. A tabletop exercise is a discussion: the team walks through a scenario and talks about the decisions, which exposes gaps in the plan and in the communication flow at very low cost. A functional exercise is hands-on, with the team using real tools to isolate systems, analyse traffic or deploy patches, so technical skill is tested under pressure. A full-scale exercise simulates a real incident across departments, testing the whole process from detection through to recovery. A plan that has never been exercised is a document, not a capability.

Slide 27 · Training and after-action review

Responders need specialised, ongoing training: threat detection, incident analysis, response strategy, and the tools of the trade. General staff need awareness, so they recognise phishing, report suspicious activity and follow policy. Then there is the after-action review, which runs after every real incident and every exercise. It asks what went well, what was difficult, and what must change. Improvements go straight back into the plan and the training. If a review found communication gaps between departments, the plan gains clearer communication protocols. The review is where the improvement actually happens.

Slide 28 · Threat hunting methods

Threat hunting assumes an attacker is already inside, looking for what the alerts missed, especially advanced persistent threats that quietly bypass ordinary defences. Hypothesis-driven investigation starts with an idea, then tests it with targeted searches. An analyst might hypothesise that rising failed logins mean brute force, then search the logs for repeated attempts from one address against many accounts. Indicator sweeping searches the estate for known indicators of compromise, such as an address, a file hash or a domain. You choose where to look, and the findings sharpen the detection rules for the next attempt.

Slide 29 · Root cause analysis

Root cause analysis asks why, not just what. It goes past the symptoms to the underlying weakness that allowed the incident in the first place. The steps run in order. Identify the problem clearly. Gather the data from logs, alerts and other sources. Analyse it for patterns and anomalies. Identify the root causes, which may be a

configuration, a behaviour, or a vulnerability. Develop solutions, implement them, then verify the fix actually holds. Without that last step the same incident comes back.

Slide 30 · Collecting and preserving evidence

Digital forensics collects, preserves and analyses electronic evidence. Collection gathers data from computers, mobile devices and network systems. Two tools make that possible. A write blocker prevents any change to a storage device during examination. Forensic imaging makes an exact, bit-by-bit copy, including deleted files and hidden data, so you analyse the copy, not the original. Hash verification compares the hash of the original against the hash of the image, which proves nothing changed. And order matters: registers first, then memory, then disk, because volatile evidence will not wait.

Slide 31 · Chain of custody and legal requirements

The chain of custody is the documented record of every person who handled the evidence, when it moved, and why. An unbroken chain proves the evidence was controlled, and a break makes it inadmissible. Legally, collection needs proper authorisation, such as a search warrant or the consent of the data owner. Privacy law still applies: the General Data Protection Regulation, or GDPR, and the Electronic Communications Privacy Act, or ECPA, shape what you may collect and keep. Evidence must be organised, documented and reported if it is to be credible.

Slide 32 · Activity: handle the evidence

[Run the activity per the instructor notes. Eight minutes in pairs, four minutes debrief.] A compromised server is found: capture the volatile data first, which means memory and open network connections. Before any analysis: image the disk and hash it. Two investigators handle the disk: every handover documented and signed. What breaks the case in court? A broken chain of custody, which makes good evidence inadmissible.

Slide 33 · Key log sources

Logs are the vital records of system, application and user activity: what happened, who was involved, and when. Security logs record successful and failed logins, privilege changes and other security events, which is how unauthorised access is spotted. System logs cover the operating system: boot events, hardware changes and errors, where unauthorised configuration change shows up. Application logs capture errors, user interactions and transactions. Network device logs from routers and switches cover traffic, status and configuration change. Firewall logs record allowed and denied traffic, which shows the attack arriving. Different sources, one timeline.

Slide 34 · Collection, centralisation and retention

Collection gathers logs from every source, usually through agents that forward them as the events happen. Centralisation aggregates them into one repository, commonly a SIEM, where events from different systems can be correlated into a single story. Retention is the policy question: how long you keep logs, when you

archive them, and when you delete them. Get retention wrong and you cannot investigate an incident you discover late, and you cannot prove compliance to an auditor. Retention is set by regulation and by what your investigations actually need. Remember: you cannot investigate what you never kept.

Slide 35 · Beyond logs: captures, memory and metadata

Beyond logs there are three more sources. A network capture records the traffic itself, which is how you examine an anomaly, confirm an intrusion and see exactly what was sent. Memory forensics analyses the contents of system memory: running processes, open network connections, and remnants left behind by malware, which is often the only trace a sophisticated attack leaves. Metadata analysis reads the information about the data, such as creation dates, authorship and modification history. Each one covers what a log cannot.

Slide 36 · Malware indicators

Now the indicators, the fingerprints malicious activity leaves behind. Viruses and worms self-replicate and spread. Trojans look benign and act maliciously. Ransomware encrypts files, renames them in bulk and leaves notes. Spyware and keyloggers exfiltrate credentials and data silently. Rootkits hide their presence and maintain privileges stealthily. Botnets show command-and-control traffic and coordinated activity. Know what each one looks like on the wire and on the host, because the exam asks you to name the indicator from the pattern.

Slide 37 · Reading the indicators

Indicators appear at every layer. On the network: port scanning, rapid probes across ports and hosts, which is reconnaissance; data exfiltration, sudden outbound spikes as data leaves the network; and command-and-control beaconing, small regular connections to a suspicious host, the heartbeat of a compromised system. At the application layer: injection probes, scanning paths, spoofed senders and malicious attachments. In behaviour: privilege escalation, accounts gaining rights they should not have, and impossible travel, logins from locations too far apart in time to be real. Indicators combine into a story, and different monitoring layers catch different ones.

Slide 38 · Activity: read the indicators

[Run the activity per the instructor notes. Eight minutes in pairs, four minutes debrief.] A server sends one megabyte every ten minutes to an unknown IP, so that is command-and-control beaconing. A user logs in from London and Sydney in ten minutes, so that is impossible travel. Files renamed with a .locked extension and a note file, so that is ransomware. Which indicator would you have caught first? That depends on your monitoring layers, and that is the point.

Slide 39 · Exam alignment

Quick alignment with the paper. Objective 11.1, monitoring and alerting: data sources, baselines, thresholds and alert fatigue. Objective 11.2, incident response: lifecycle phases, containment, eradication and recovery. Objective 11.3, forensics: chain of custody, order of volatility, imaging and techniques. Objective 11.4, indicators: malware, network, application and behavioural. The chapters you have just covered map onto those objectives directly.

Slide 40 · Quiz

[Direct candidates to [Quiz_Session_11.html](#). Fifteen minutes.] Open the session quiz. Twenty questions, immediate feedback, and every question is tagged with the exam objective it tests, so you will see the tag, like 11.2 Incident Response, above each question. Read every explanation, because the distractors teach as much as the answer. Aim for seventy percent or better.

Slide 41 · Key takeaways

Six takeaways. One: use the right monitoring sources and tune the alerts, or good alarms get ignored. Two: match the control to the layer, so firewall and NGFW for the network, NAC for the device, DLP for the data, and EDR for the endpoint. Three: identity is the perimeter, so provision, deprovision and protect privilege. Four: respond through the four phases, and test the plan before you need it. Five: preserve volatile evidence first, and keep the chain of custody unbroken. Six: know your log sources, and know how long you retain them.

Slide 42 · Revision checklist

Before next session: retake the quiz until you score seventy percent without guessing. Write a playbook: decide which steps you would automate, and where a human must keep the decision. Walk the four phases and know who leads, what tools you would use, and when to escalate. Practise volatility by listing your own systems in capture order, memory before disk. And read ahead to Session 12, the final session: governance, risk, compliance and data protection.

Slide 43 · Next session preview

Next time we close the course: Governance, Risk, Compliance and Data Protection. Policies and standards, risk management processes, compliance and privacy, which is the layer that turns security from technical work into organisational behaviour. Before then, keep one habit from today: when an alert arrives, establish the facts from the logs before you act on the story, and preserve the evidence while you still can. See you there.